

RETEST ETHICAL HACKING

Proyecto: DT.Claro.Miniprogram.TuLlave_Mass | Fecha: 21/05/2026

Target API: <https://urs.qa.vettica.co> | Total hallazgos: 9
Crítica: 1 | Alta: 0 | Media: 2 | Baja: 6
Priorización: 9 hallazgos — 1 críticos
- Priorizar remediación de hallazgos CRITICAL (secretos, inyección, auth rota).
- 5 check(s) externo(s) omitido(s) (binario ausente o requisito no cumplido); ver tabla en el informe.
Extensiones analizadas: .acss, .axml, .js, .json

Endpoints analizados

#	Metodo	Path	Hallazgos
1	GET	/card/valid/	0
2	GET	/card/getBalance/	0
3	GET	/card/getInformation/	0

#	Vulnerabilidad	Riesgo	CVSS	Estado	Endpoint
1	Hardcoded Credentials	CRITICAL	9.0	Persistente	https://urs.qa.vettica.co
2	Sensitive Data in Logs	MEDIUM	6.0	Persistente	https://urs.qa.vettica.co
3	Falta cabecera Strict-Transport-Security (HSTS)	MEDIUM	6.0	Persistente	https://urs.qa.vettica.co
4	Falta X-Content-Type-Options	LOW	3.0	Persistente	https://urs.qa.vettica.co
5	Falta Referrer-Policy	LOW	3.0	Persistente	https://urs.qa.vettica.co
6	Validación manual requerida: BOLA/IDOR por objeto	LOW	3.0	Persistente	https://urs.qa.vettica.co
7	Validación manual requerida: BFLA por rol	LOW	3.0	Persistente	https://urs.qa.vettica.co
8	Validación manual requerida: Mass Assignment	LOW	3.0	Persistente	https://urs.qa.vettica.co
9	Validación manual requerida: JWT claims/TTL/revocación	LOW	3.0	Persistente	https://urs.qa.vettica.co

Detalle tecnico

1. Hardcoded Credentials (CRITICAL)

Estado: Persistente | CWE: CWE-798
Endpoint: <https://urs.qa.vettica.co>
Descripcion: Coincidencia de patrón HARDCODED_CREDENTIALS en main/ui/pages/pseForm/pseForm.js:222.
Recomendacion: No almacenes contraseñas en código; usa gestores de secretos.

2. Sensitive Data in Logs (MEDIUM)

Estado: Persistente | CWE: CWE-532
Endpoint: <https://urs.qa.vettica.co>
Descripcion: Coincidencia de patrón SENSITIVE_DATA_LOGGING en main/ui/pages/rechargeAmount/rechargeAmount.js:194.
Recomendacion: No registres contraseñas ni tokens; usa enmascaramiento o niveles de log seguros.

3. Falta cabecera Strict-Transport-Security (HSTS) (MEDIUM)

Estado: Persistente | CWE: CWE-319

Endpoint: <https://urs.qa.vettica.co>

Descripción: No se detectó HSTS en la respuesta; los clientes no reciben la política de forzar HTTPS.

Recomendación: Añade HSTS con un max-age adecuado (y preload si aplica) en el balanceador o API gateway.

4. Falta X-Content-Type-Options (LOW)

Estado: Persistente | CWE: CWE-16

Endpoint: <https://urs.qa.vettica.co>

Descripción: La respuesta no incluye X-Content-Type-Options: nosniff.

Recomendación: Agrega X-Content-Type-Options: nosniff en API gateway/backend.

5. Falta Referrer-Policy (LOW)

Estado: Persistente | CWE: CWE-16

Endpoint: <https://urs.qa.vettica.co>

Descripción: No se encontró cabecera Referrer-Policy en la respuesta del API.

Recomendación: Configura Referrer-Policy estricta (p. ej., no-referrer).

6. Validación manual requerida: BOLA/IDOR por objeto (LOW)

Estado: Persistente | CWE: CWE-639

Endpoint: <https://urs.qa.vettica.co>

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Ejecuta pruebas con dos identidades y cruza IDs para detectar acceso indebido a recursos de terceros.

7. Validación manual requerida: BFLA por rol (LOW)

Estado: Persistente | CWE: CWE-285

Endpoint: <https://urs.qa.vettica.co>

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Prueba endpoints de privilegio alto con cuentas de menor rol y verifica denegación consistente.

8. Validación manual requerida: Mass Assignment (LOW)

Estado: Persistente | CWE: CWE-915

Endpoint: <https://urs.qa.vettica.co>

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Intenta campos no permitidos en payloads (role, status, flags internos) y valida whitelists server-side.

9. Validación manual requerida: JWT claims/TTL/revocación (LOW)

Estado: Persistente | CWE: CWE-613

Endpoint: <https://urs.qa.vettica.co>

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Verifica exp/iat/nbf/aud/iss/jti, rotación de claves y revocación de tokens.